

RELATÓRIO DE IMPACTO À PROTEÇÃO DE DADOS PESSOAIS (RIPD)

PROJETO INVEST+

1. IDENTIFICAÇÃO DOS AGENTES E ENCARREGADO

Controlador: Projeto Invest+ (Equipe de Desenvolvimento).

Encarregado de Dados (DPO): Gabriel Yukio Yamaguti Minato
(gabrielyyminato@gmail.com).

Outras partes envolvidas (Operadores): Provedores de nuvem para hospedagem (Railway Corp) e serviço de mensageria terceirizado para envio de e-mails.

2. JUSTIFICATIVA PARA A ELABORAÇÃO

O RIPD é elaborado em atenção ao princípio da responsabilização e prestação de contas da LGPD. A justificativa é o tratamento de dados financeiros para automação de carteiras e o uso de processos de perfilamento automatizado, que podem ser considerados como "alto risco" por afetarem significativamente os interesses financeiros e direitos do titular.

3. SISTEMAS DE INFORMAÇÃO ENVOLVIDOS

As operações ocorrem na arquitetura da plataforma, envolvendo:

- Banco de Dados: H2 Database (In-Memory/MVP).
- Back-end: API Java 25 (Spring Boot 3.5).
- Front-end: React (Vite).

4. DESCRIÇÃO DO TRATAMENTO DE DADOS

Categorias de Titulares: Usuários em geral da plataforma Invest+ (clientes).

Fonte de Coleta: Direta com o titular, através de formulários cifrados preenchidos na plataforma.

Dados Pessoais Simples: Nome completo, E-mail de login, e Dados Eletrônicos (Endereço IP e logs de acesso).

Dados de Alto Risco (Financeiros e Perfilamento): Saldos, aportes, quantidades, preços médios, ativos, respostas qualitativas e metas de alocação.

Volume: *(Campo a ser dimensionado conforme o crescimento da base de usuários na plataforma de produção).*

5. FINALIDADE, HIPÓTESE LEGAL E ARMAZENAMENTO

Processo 1: Gestão Patrimonial e Perfilamento

Finalidade: Autenticação no sistema, cálculos de rentabilidade, rebalanceamento automático de carteira e recomendações baseadas no perfil de risco do usuário.

Hipótese Legal: Execução de Contrato (Art. 7º, inciso V da LGPD).

Retenção: Mantidos durante todo o período em que a conta do usuário estiver ativa. A exclusão da conta acarreta a remoção irreversível do histórico.

Processo 2: Retenção de Logs

Finalidade: Auditoria de sistema e segurança.

Hipótese Legal: Cumprimento de Obrigação Legal/Regulatória (Marco Civil da Internet).

Retenção: Pelo prazo legal obrigatório de 6 meses.

6. COMPARTILHAMENTOS DE DADOS

O compartilhamento externo ocorre apenas com operadores essenciais para o funcionamento da plataforma: banco de dados hospedado criptografado na Railway Corp e envio de alertas via serviços de mensageria de e-mails. Não ocorre a venda de dados a terceiros.

7. RISCOS IDENTIFICADOS E MEDIDAS DE MITIGAÇÃO

Para mitigar os riscos de vazamento de dados, acesso não autorizado ou violação de confidencialidade de informações patrimoniais, o Invest+ implementou as seguintes salvaguardas técnicas estruturais e documentadas na PSI:

Criptografia em Repouso: Os dados pessoais (nome/e-mail) e os dados financeiros de domínio são salvos no banco de dados com cifragem de alto padrão AES-256 GCM.

Hashing e Proteção de Credenciais: As senhas de usuários não são salvas em texto claro, mas com o algoritmo de altíssima resistência Argon2. A pesquisa de e-mails usa *Blind Indexing* com SHA-256, e os tokens de recuperação utilizam HMAC-SHA256.

Segurança em Trânsito: Obrigatório o uso do protocolo TLS 1.2+ via HTTPS para fechar as pontas de comunicação do sistema e transmissão dos tokens JWT com assinatura HS256.

Controle de Acesso: A plataforma exige a Autenticação de Dois Fatores (2FA) gerada via *SecureRandom*. A visibilidade dos dados é isolada apenas para o dono da conta pelo Princípio do Privilégio Mínimo (IAM) gerido em nível de aplicação.